

Cisco Secure Workload - MITRE ATT&CK Compliance Report

Cisco Secure Workload - MITRE ATT&CK Compliance Report

Customer-Facing Compliance Report

Framework: MITRE ATT&CK Enterprise (<https://attack.mitre.org>)

Primary audience: Security architects, detection engineers, threat hunters, SOC analysts, and red-team / purple-team functions using ATT&CK as the common reference for adversary behaviour.

CSW positioning: ATT&CK is not a compliance framework. CSW supports a subset of ATT&CK tactics with workload-level prevention and detection evidence, primarily Lateral Movement (TA0008), Discovery (TA0007), Command and Control (TA0011) detection of egress, Exfiltration (TA0010) detection, and Initial Access (TA0001) reduction by reducing reachable surface.

Framework Version Note

MITRE ATT&CK is a living knowledge base; the version evolves periodically (current version at time of writing is v15). This report references the high-level tactics (TA0001 through TA0040 / TA0011 family). Validate technique-level mappings against the ATT&CK version your detection-engineering team is using.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The reference design (CSW-MITRE-ATTACK-Technical-Reference design.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

MITRE-ATTACK

(no fixed scope tree; ATT&CK is a tactic / technique cross-cut applied to any CSW-instrumented scope)

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Initial Access (TA0001) - reachable-surface reduction
- Discovery (TA0007) - lateral discovery flow detection
- Lateral Movement (TA0008) - east-west flow detection and prevention
- Command and Control (TA0011) - egress flow detection
- Exfiltration (TA0010) - egress flow detection
- Impact (TA0040) - workload reach scoping during impact analysis

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Execution (TA0002) - endpoint behaviour (EDR domain)
- Persistence (TA0003) - host-level (EDR domain)
- Privilege Escalation (TA0004) - host-level (EDR domain)
- Defense Evasion (TA0005) - many techniques are host-level (EDR domain)
- Credential Access (TA0006) - identity layer (IAM / EDR)
- Collection (TA0009) - host-level (EDR / DLP)

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Initial Access (TA0001) - reduce reachable surface	Direct	Reachability-weighted vulnerability evidence; policy workspace deny by default	Vulnerability report + workspace snapshot showing reduced ingress paths
Discovery (TA0007) - detect lateral discovery flows	Direct	Process + flow telemetry; alerts on unexpected scanning patterns	Alert log for unauthorised east-west reconnaissance
Lateral Movement (TA0008) - east-west enforcement and detection	Direct	Policy workspace + enforcement / violation log	Workspace snapshot + violation log showing east-west allowlist enforcement
Command and Control (TA0011) - egress detection	Direct	Outbound flow telemetry with destination context	Egress flow report and anomaly alerts
Exfiltration (TA0010) - egress detection	Direct	Outbound flow telemetry with destination context and volume context	Egress flow report with volume anomalies
Impact (TA0040) - reach scoping	Direct	Forensic flow + process search	Investigation pack showing reach from the impacted workload

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Reachable-surface reduction	Reduced ingress paths to high-value workloads	Policy workspace export + reachability summary	Quarterly + after each major workspace change
Lateral-movement enforcement	East-west allowlist enforcement and violation log	Policy workspace export + policy analysis output	Continuous; reviewed quarterly
Egress monitoring	Outbound flow telemetry to external	Flow search filtered to external	Continuous; reviewed daily for high-value

Topic	What to collect	CSW source	Suggested cadence
	destinations	destinations	scopes
Detection content (joint with SOC)	ATT&CK-mapped detection rules using CSW telemetry	SOC integration (CSW telemetry exported to SIEM)	Continuous; rule sets reviewed monthly

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. `tenant`, `prototype`, `isa_level`, `npi`, `cui`, `ephi`).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

ATT&CK is not a compliance standard. CSW does not replace EDR, SIEM, identity telemetry, malware analysis, endpoint response, threat intelligence, or the full detection engineering function. CSW is one telemetry source among many for an ATT&CK-aligned SOC.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.